To enforce a certificate binding on an access token, you need to check the token introspection response for a `cnf` field containing a confirmation key. The confirmation key is a JSON object whose fields are the confirmation methods and the values are the determined by each method. Loop through the required confirmation methods as shown in listing 11.9 to ensure that they are all satisfied. If any aren't satisfied, or your API doesn't understand any of the confirmation methods, then you should reject the request so that a client can't access your API without all constraints being respected.

> **TIP** The JWT specification for confirmation methods (RFC 7800, https://tools.ietf.org/html/rfc7800) requires only a single confirmation method to be specified. For robustness you should check for other confirmation methods and reject the request if there are any that your API doesn't understand.

Listing 11.9 shows how to enforce a certificate-bound access token constraint by checking for an `x5t#S256` confirmation method. If a match is found, base64url-decode the confirmation key value to obtain the expected hash of the client certificate. This can then be compared against the hash of the actual certificate the client has used to authenticate to the API. In this example, the API is running behind the Nginx ingress controller, so the certificate is extracted from the `ssl-client-cert` header.

> **CAUTION** Remember to check the `ssl-client-verify` header to ensure the certificate authentication